

Mount Kenya University

Unlocking Infinite Possibilities

Student Name	Eddy Kering
Admission Number	BSCCS/2024/61947
Course	Bachelor of Science in Computer Science
Unit Code	BIT4139
Unit Name	Ethical Hacking and Counter measures
Lecturer	Michael Nyoro
Semester / Year	2026

Weeks 1 – 5 | May – June 2026

Table of Contents

Week 1: Network Scanning with Nmap.....	3
1.1 Tool Installation.....	3
1.2 Open Ports Scan.....	3
1.3 Vulnerability Test.....	4
1.4 Footprinting (OS and Service Detection).....	4
Student Reflection — Week 1.....	5
 Week 2: Advanced Nmap Scanning Techniques.....	 6
2.1 Scan Ports.....	6
2.2 Identify OS Version.....	6
2.3 Detect Running Services.....	7
2.4 Enumerate Users and Shared Folders.....	7
2.5 Detect Vulnerabilities.....	7
Student Reflection — Week 2.....	8
 Week 3: Passive OSINT Reconnaissance — Safaricom PLC.....	 9
Introduction.....	9
Organization Overview.....	9
Summary of Findings.....	9
3.1 Domain and Registrar Information.....	10
3.2 IP Address Information.....	10
3.3 Subdomain Discovery.....	11
3.4 Open Services (Shodan.io).....	12
3.5 Email Patterns.....	13
3.6 Leaked Credentials (IntelligenceX).....	13
3.7 Technology Stack (Wappalyzer).....	14
3.8 Security Recommendations.....	15
Conclusion.....	15
Student Reflection — Week 3.....	16
 Week 4: Scanning Networks — Nmap Against Metasploitable 2.....	 17
4.1 Lab Setup.....	17
4.2 Open Ports Scan.....	17
4.3 OS and Service Detection.....	18
4.4 Banner Grabbing.....	18
4.5 Vulnerability Detection.....	19
Student Reflection — Week 4.....	19

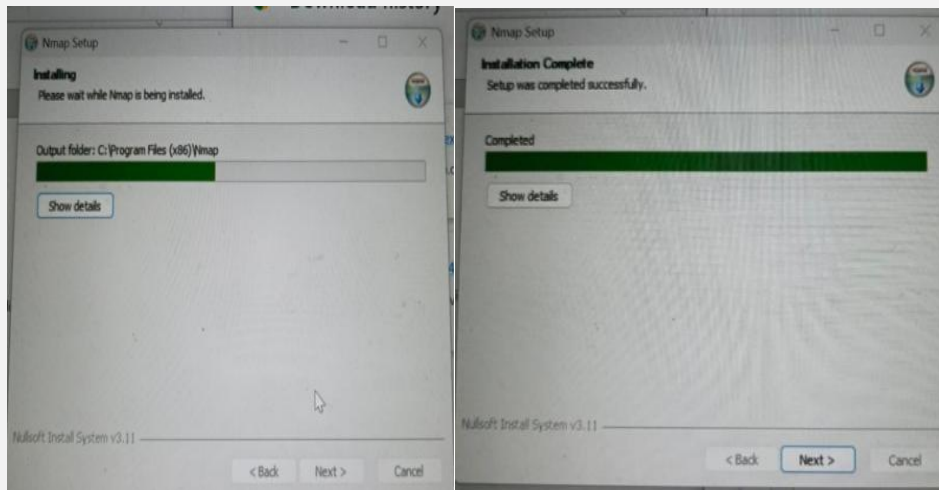
Week 5: Enumeration — NetBIOS, SNMP, LDAP, and SMTP on Metasploitable 2.....	20
5.1 Overview.....	20
5.2 NetBIOS Enumeration.....	20
5.3 SNMP Enumeration.....	21
5.4 LDAP Enumeration.....	21
5.5 SMTP Enumeration.....	22
5.6 Enumeration Countermeasures.....	22
Student Reflection — Week 5.....	23

Week 1: Introduction to Ethical Hacking — Network Scanning with Nmap

Date	May 21, 2026
Week	Week 1
Tool(s) Used	Nmap (Network Mapper) — Zenmap GUI
Target	192.168.0.101 (Local Network Host)
Objective	Install Nmap on Windows and perform open port scanning and OS/service detection on a local host

1.1 Tool Installation

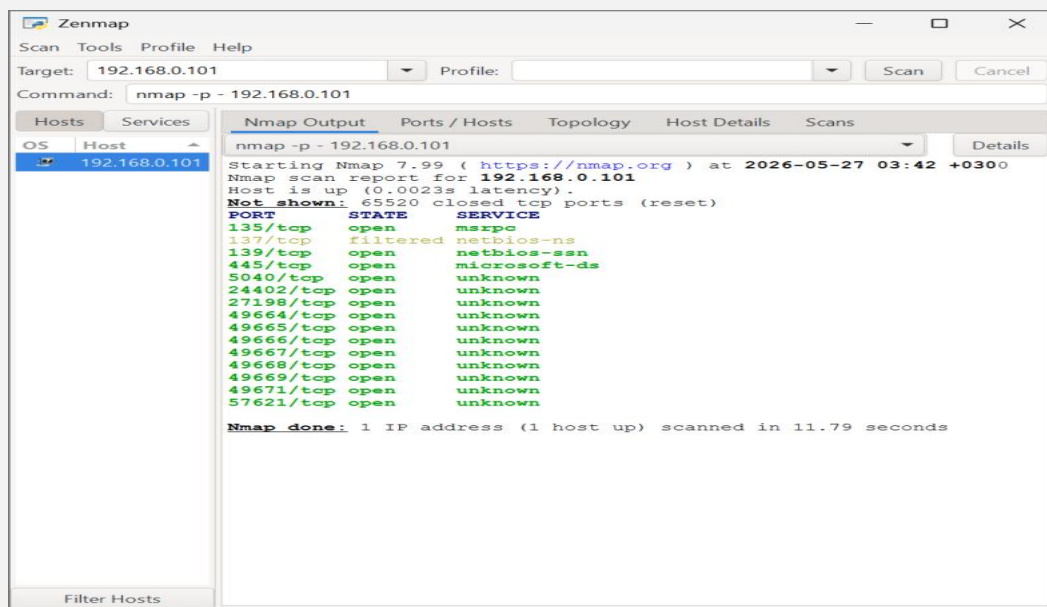
Nmap was downloaded from the official website (nmap.org) and installed on a Windows system. The Zenmap graphical interface was installed alongside the command-line version for ease of use. Installation was completed successfully with the output folder configured to C:\Program Files (x86)\Nmap.



Nmap/Zenmap installation complete screen or the program open on the Windows desktop

1.2 Open Ports Scan

A full port scan was conducted on target host 192.168.0.101 using the command `nmap -p- 192.168.0.101` to scan all 65,535 TCP ports. The scan completed in 11.79 seconds.

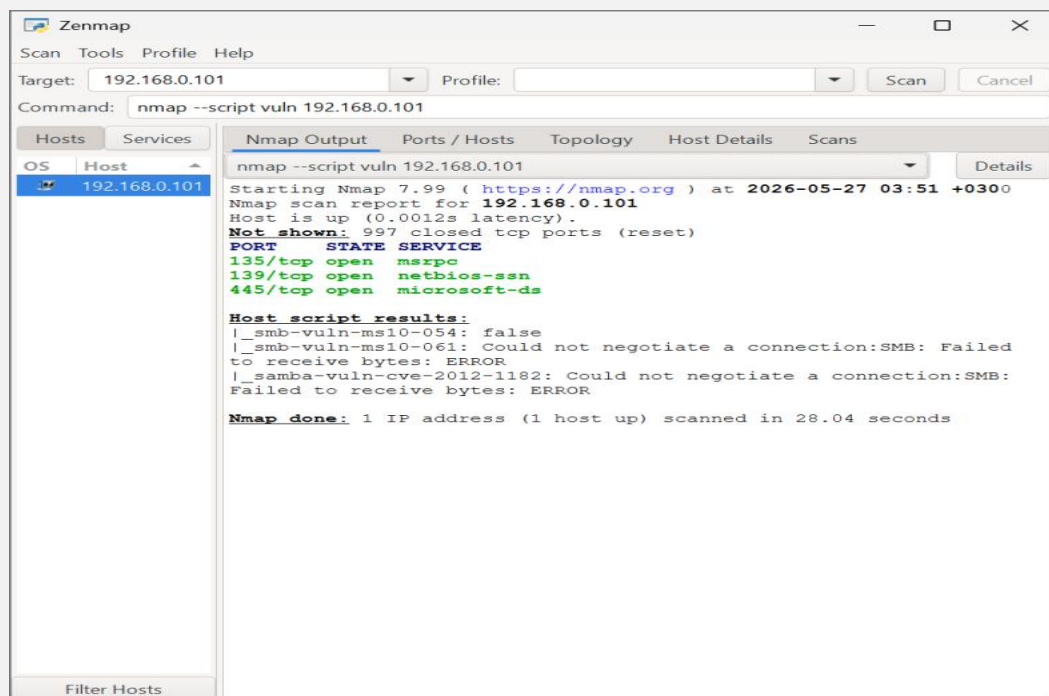


Zenmap or terminal output of: nmap -p- 192.168.0.101

Port / Protocol	State	Service
135/tcp	open	msrpc
137/tcp	filtered	netbios-ns
139/tcp	open	netbios-ssn
445/tcp	open	microsoft-ds
5040/tcp	open	unknown
24402/tcp	open	unknown
27198/tcp	open	unknown
49664–49669/tcp	open	unknown
49671/tcp	open	unknown
57621/tcp	open	unknown

1.3 Vulnerability Test

A vulnerability scan was performed using Nmap's scripting engine with the command `nmap --script vuln 192.168.0.101`. This ran known CVE detection scripts against the open ports.



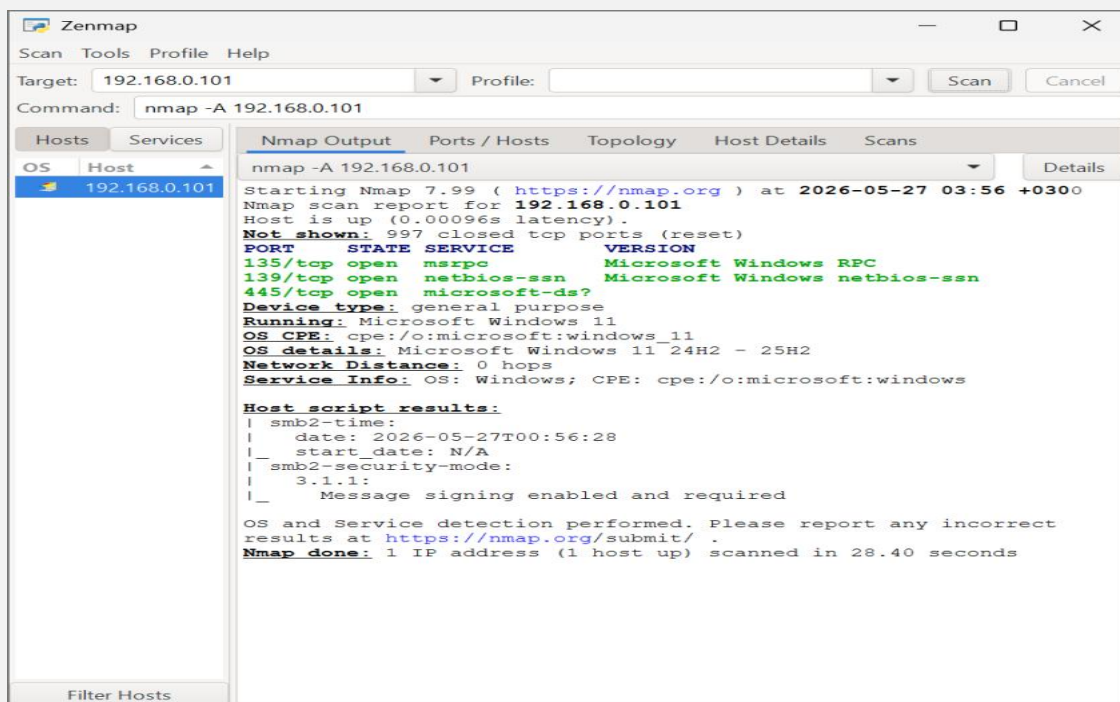
Terminal output of: `nmap --script vuln 192.168.0.101` (show the script results section)

Script	Result
smb-vuln-ms10-054	false — Not vulnerable
smb-vuln-ms10-061	Could not negotiate SMB connection — ERROR
samba-vuln-cve-2012-1182	Could not negotiate SMB connection — ERROR

The SMB vulnerability scripts could not fully negotiate a connection, indicating the host runs a newer SMB dialect (SMBv2/v3) that older scripts do not support. The ms10-054 script returned false, indicating no vulnerability was detected for that CVE.

1.4 Footprinting (OS and Service Detection)

An aggressive scan was run using `nmap -A 192.168.0.101` to perform OS detection, service version detection, and script scanning. This scan completed in 28.40 seconds.



Terminal output of: `nmap -A 192.168.0.101` (show OS detection and service version section)

Attribute	Finding
OS Detected	Microsoft Windows 11 (24H2 – 25H2)
Device Type	General Purpose
OS CPE	cpe:/o:microsoft:windows_11
Network Distance	0 hops
SMB Security Mode	3.1.1 — Message signing enabled and required
SMB2 Time	2026-05-27T00:56:28

Student Reflection — Week 1

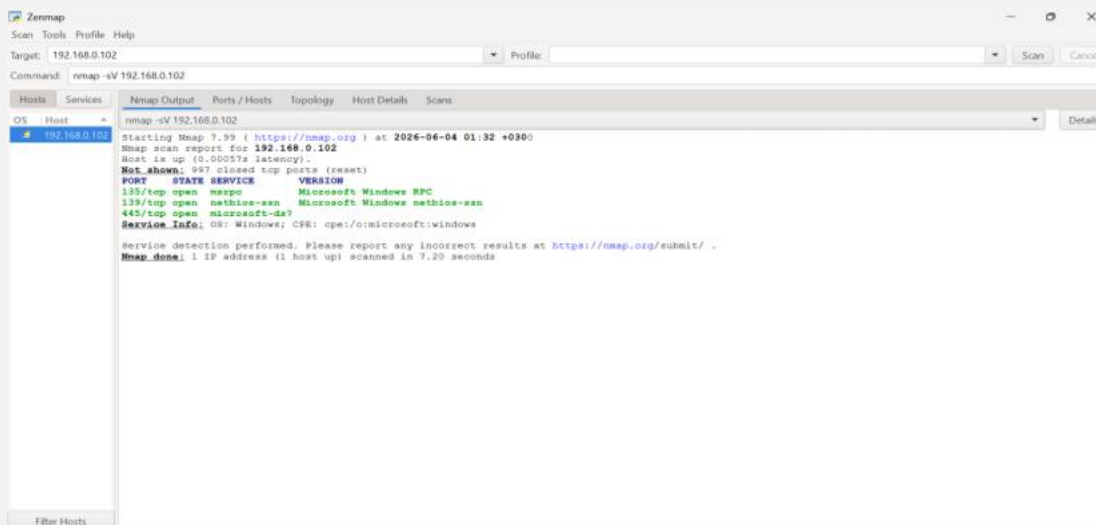
This week introduced Nmap as a core network reconnaissance tool. Installing it on Windows and using the Zenmap GUI made it straightforward to run structured scans. The open port scan revealed that the target Windows 11 host exposes SMB-related services (ports 135, 139, 445), which are common attack surfaces. The aggressive scan confirmed the OS version and that SMB message signing is enforced — a positive security control. The vulnerability scripts could not negotiate an SMB session, highlighting that modern Windows hosts have improved defences against older exploit techniques.

Week 2: Penetration Testing Basics — Advanced Nmap Scanning

Date	May 28, 2026
Week	Week 2
Tool(s) Used	Nmap (Network Mapper) — Zenmap GUI
Target	192.168.0.101 (Local Network Host)
Objective	Perform advanced Nmap scans: OS identification, service version detection, SMB user enumeration, and CVE-based vulnerability detection

2.1 Scan Ports

A targeted port scan was conducted to identify active services running on the host. The scan confirmed the presence of standard Windows networking ports and several high-numbered dynamic ports used by the RPC endpoint mapper.



Zenmap or terminal showing port scan results for 192.168.0.101

2.2 Identify OS Version

OS version detection was performed using the aggressive scan flag (-A) and confirmed via SMB2 protocol negotiation.

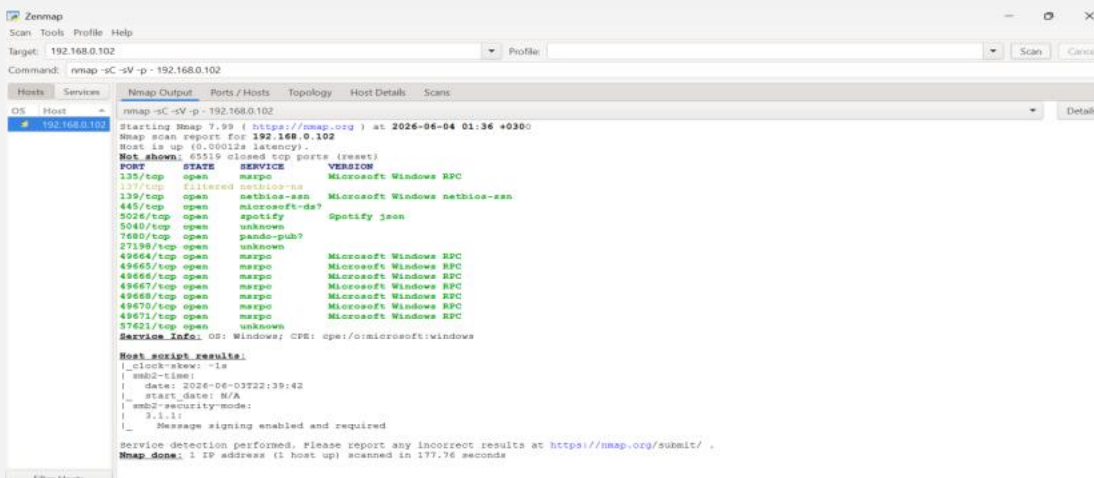


Nmap output showing OS detection result (look for 'OS details:' line in terminal)

Detection Method	Result
OS Detection (-O flag)	Microsoft Windows 11 24H2 – 25H2
CPE String	cpe:/o:microsoft:windows_11
SMB2 Dialect	3.1.1 (confirmed via smb2-time script)
Confidence	High (direct response, 0 hops)

2.3 Detect Running Services

Service and version detection (-sV) identified the following services on the target host:



Nmap -sV output showing service versions for the open ports

Port	Service	Version / Details
135/tcp	msrpc	Microsoft Windows RPC
139/tcp	netbios-ssn	Microsoft Windows netbios-ssn
445/tcp	microsoft-ds	Microsoft Windows SMB (SMBv3.1.1)

2.4 Enumerate Users and Shared Folders

SMB enumeration scripts were used via the Nmap Scripting Engine (NSE) with the command: `nmap --script smb-enum-shares,smb-enum-users 192.168.0.101`

- SMB dialect confirmed as 3.1.1.
- Message signing: enabled and required.
- Direct user enumeration was not possible — authentication required; guest access disabled (Windows 11 default hardening).

```

kali@kali:~$ enum4linux -a 192.168.0.2
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Wed Jun 3 19:01:48 2020

===== ( Target Information ) =====
Target ..... 192.168.0.2
MAC Range ..... 300-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 192.168.0.2 ) =====
[E] Can't find workgroup/domain

===== ( Netstat Information for 192.168.0.2 ) =====
Looking up status of 192.168.0.2
No reply from 192.168.0.2

===== ( Session Check on 192.168.0.2 ) =====
[E] Server doesn't allow session using username '', password ''. Aborting re
mainder of tests.

kali@kali:~$

```

2.5 Detect Vulnerabilities

Vulnerability detection scripts from the NSE were executed using `nmap --script vuln`, targeting common SMB and Windows CVEs.



Terminal output of: `nmap --script vuln 192.168.0.101` (show the script result lines)

CVE / Script	Result	Interpretation
ms10-054 (SMB Buffer Overflow)	false	Not vulnerable
ms10-061 (Print Spooler)	SMB negotiate error	Unable to test — dialect mismatch
CVE-2012-1182 (Samba RCE)	SMB negotiate error	Unable to test — not a Samba host

Student Reflection — Week 2

This week expanded Nmap usage to structured reconnaissance: OS fingerprinting, service version detection, SMB enumeration, and CVE-based vulnerability scanning. The target was confirmed as a hardened Windows 11 machine with SMB message signing enforced, guest access disabled, and no detectable legacy vulnerabilities. This demonstrates that modern Windows builds have improved default security postures and that reconnaissance results must be interpreted carefully rather than treated as definitive exploit opportunities.

Week 3: Footprinting & Reconnaissance — Passive OSINT on Safaricom PLC

Date	May 28, 2026
Week	Week 3
Tool(s) Used	OSINT Framework, ViewDNS.info, Shodan.io, Email-Format.com, IntelligenceX, Wappalyzer
Target	Safaricom PLC (safaricom.co.ke)
Objective	Gather publicly available information about Safaricom's digital footprint using passive OSINT — no active scanning or unauthorized access

3.1 Introduction

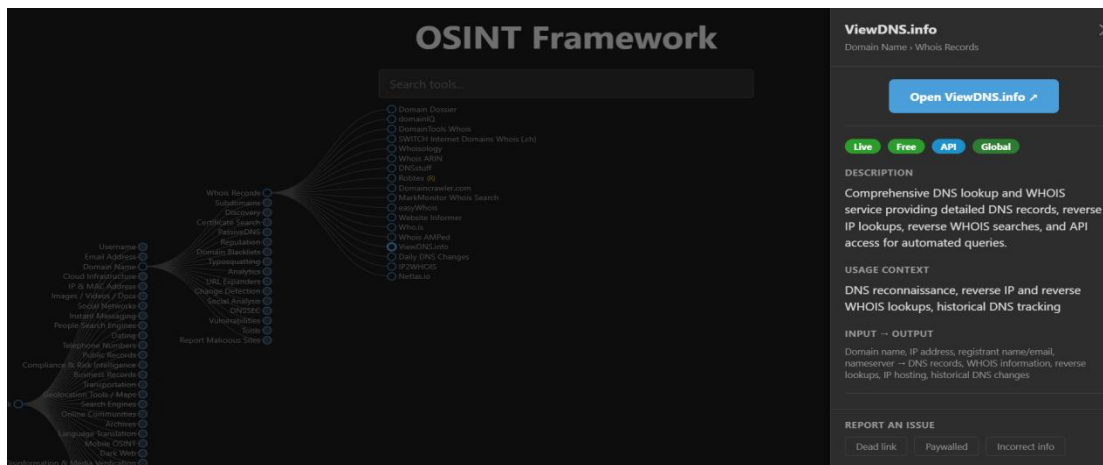
This exercise demonstrates how publicly available information can be systematically gathered to understand an organization's digital footprint without any active scanning or unauthorized access. All information was obtained from publicly accessible tools only. No exploitation or intrusion was performed. The exercise was conducted strictly for academic purposes.

3.2 Summary of Findings

Task	Tool Used	Key Finding
Domain Information	ViewDNS.info Whois	Self-registered by Safaricom; active since 2003, expires 2030
IP Address	ViewDNS.info IP History	Currently behind Imperva WAF; origin IP is hidden
Subdomain Discovery	ViewDNS.info Subdomains	17+ subdomains found including internal IP leaks
Open Services	Shodan.io	898 indexed results; FortiGate firewall nodes visible
Email Patterns	Email-Format.com	8 patterns identified, all with low confidence
Leaked Credentials	IntelligenceX	1,341 files referencing the domain in breach databases
Technology Stack	Wappalyzer	Joomla/PHP/Nginx on AWS; outdated JS libraries

3.3 Domain and Registra information

Tool Used: ViewDNS.info



WHOIS Information for safaricom.co.ke

```
Domain Name: safaricom.co.ke
Registry Domain ID: 1403-Kenic
Registrar URL: http://domains.safaricom.co.ke
Updated Date: 2025-10-16T06:36:04Z
Creation Date: 2003-02-12T21:00:00Z
Registry Expiry Date: 2030-12-31T21:00:00Z
Registrar Registration Expiration Date: 2030-12-31T21:00:00Z
Registrar: Safaricom Limited
Registrar Street Address: Safaricom House
P.O. Box 46350 - 001001
Nairobi
Registrar Phone: 0722002222
Registrar Email: ebt-domains@Safaricom.co.ke
Registrar Abuse Contact Email:
Registrar Abuse Contact Phone:
Domain Status: active https://icann.org/epp#active
Name Server: ns4.safaricombusiness.co.ke
Name Server: ns1.safaricombusiness.co.ke
Name Server: ns2.safaricombusiness.co.ke
Name Server: ns3.safaricombusiness.co.ke
DNSSEC: signedDelegation
```

3.4 IP Address Discovery

Tool Used:ViewDNS.info

IP history results for 'safaricom.co.ke'.

There are 5 historical IP addresses for this domain.

IP ADDRESS	LOCATION	IP ADDRESS OWNER	LAST SEEN ON THIS IP
45.223.28.17	United States	INCAPSULA	2026-05-31
45.223.18.17	United States	INCAPSULA	2026-05-31
196.201.214.47	Nairobi - Kenya	SAFARICOM-LIMITED	2020-06-10
196.201.213.56	Nairobi - Kenya	SAFARICOM-LIMITED	2016-04-14
196.201.214.47	Nairobi - Kenya	SAFARICOM-LIMITED	2016-04-13

3.5 Subdomain Discovery

Tool Used:ViewDNS.info

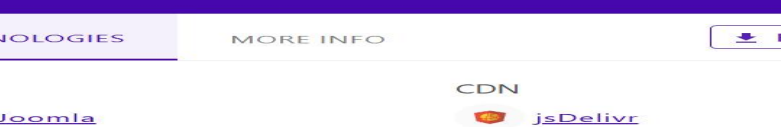
Subdomain	IP Address	Purpose
7s.safaricom.co.ke	197.248.2.35	Rugby/Sports portal
accounts.safaricom.co.ke	45.60.12-20.229 (5 IPs)	Customer accounts portal
ads.safaricom.co.ke	196.201.213.134	Active Directory Federation Services
admin.partnerworkspace.safaricom.co.ke	10.184.165.4 (Internal)	Partner admin portal
adxdsp-uat.safaricom.co.ke	67.207.80.13	Ad Exchange test environment
afya.safaricom.co.ke	197.248.2.37	Health services portal
agm.safaricom.co.ke	196.201.213.182	Annual General Meeting portal
api.dxlapi.safaricom.co.ke	45.60.13.220 /	DXL API gateway

Subdomain	IP Address	Purpose
	45.60.87.21	
api.partnerworkspace.safaricom.co.ke	10.184.165.4 (Internal)	Partner API endpoint
api.safaricom.co.ke	196.201.214.202	Main public API endpoint
apicctv.safaricom.co.ke	197.248.8.119	CCTV/Surveillance API
appstg.safaricom.co.ke	41.90.220.125	Application staging environment
archive.safaricom.co.ke	196.201.213.112	Archive portal
2fa.safaricom.co.ke	No IP	Two-factor authentication service
abbybot.safaricom.co.ke	No IP	AI chatbot (Abby)
admin.business.safaricom.co.ke	No IP	Business administration portal
admin.county.safaricom.co.ke	No IP	County-level administration portal

3.6 Open Services

Tool Used:Shodan.io

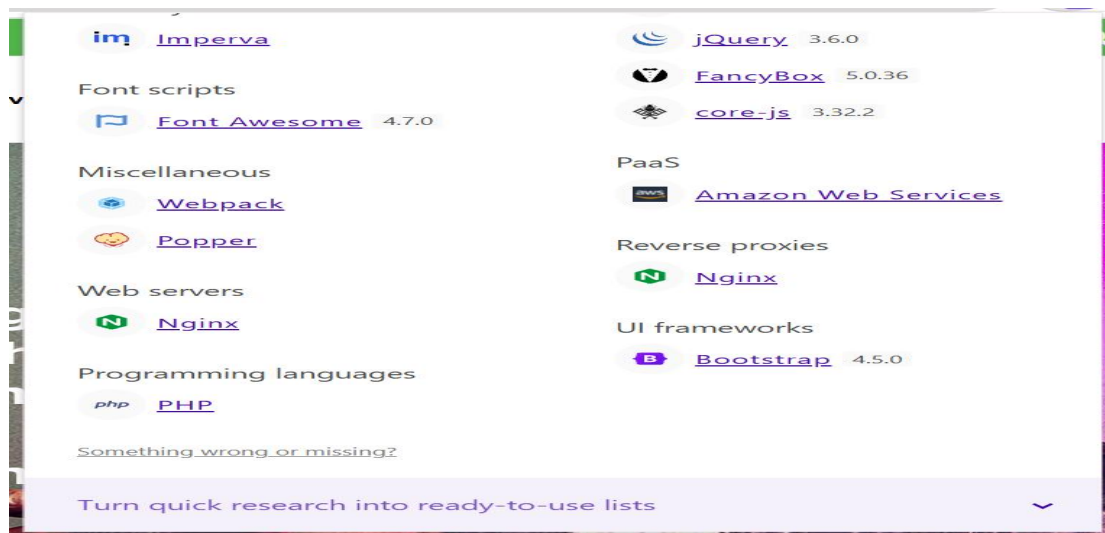
[illegible]



Wappalyzer

TECHNOLOGIES MORE INFO [Export](#)

- CMS**
 -  [Joomla!](#)
- Analytics**
 -  [Microsoft Clarity](#)
 -  [Google Analytics](#) GA4
 -  [Facebook Pixel](#)
 -  [Dynatrace](#)
 -  [LinkedIn Insight Tag](#)
- Security**
 -  [Imperva](#)
- CDN**
 -  [jsDelivr](#)
 -  [Imperva](#)
 -  [Amazon CloudFront](#)
- Tag managers**
 -  [Google Tag Manager](#)
- JavaScript libraries**
 -  [Swiper](#)
 -  [jQuery UI](#) 1.12.1
 -  [jQuery](#) 3.6.0



3.10 Security Recommendations

- DNS Hygiene: Remove private IP addresses (10.184.165.4) from public DNS. Restrict UAT/staging subdomains to internal access only.
- Software Updates: Upgrade jQuery, jQuery UI, Bootstrap, and Font Awesome to current versions to eliminate known CVEs.
- Breach Response: Investigate the 1,341 files on IntelligenceX; disable any confirmed leaked credentials immediately.
- Ongoing Monitoring: Implement continuous OSINT monitoring via Shodan and IntelligenceX; conduct formal assessments at least annually.

Student Reflection — Week 3

This exercise demonstrated that a substantial amount of sensitive information about a major organization is publicly accessible without any active scanning. Using only free tools, it was possible to map Safaricom's infrastructure, identify internal IP leaks in public DNS, discover exposed staging environments, and find evidence of over 1,300 files in breach databases. Passive reconnaissance is a critical phase of any penetration test and organizations must actively monitor their public digital footprint.

Week 4: Scanning Networks — Nmap Against Metasploitable 2

Date	June 4, 2026
Tool Used	Nmap (Network Mapper) — Zenmap GUI
Target	192.168.56.101 (Metasploitable 2 — VirtualBox Host-Only Network)
Objective	Perform structured network scanning against a deliberately vulnerable Linux machine: port scanning, OS detection, service version detection, banner grabbing, and CVE-based vulnerability detection

4.1 Lab Setup

Metasploitable 2 is a deliberately vulnerable Linux virtual machine designed for practising penetration testing techniques in a safe, legal environment. It was set up in VirtualBox using a Host-Only network adapter, which isolates it from the internet while allowing the host Windows machine to communicate with it. The VM was booted and its IP address confirmed using the `ifconfig` command inside the VM.

```
msfadmin@metasploitable:~$ root
-bash: root: command not found
msfadmin@metasploitable:~$ user "root"
-bash: userroot: command not found
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:20:08:cd
          inet addr:192.168.56.101  Bcast:192.168.56.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe20:8cd/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:47 errors:0 dropped:0 overruns:0 frame:0
          TX packets:61 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:6960 (6.7 KB)  TX bytes:9661 (9.4 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:232 errors:0 dropped:0 overruns:0 frame:0
          TX packets:232 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:89257 (87.1 KB)  TX bytes:89257 (87.1 KB)

msfadmin@metasploitable:~$
```

VirtualBox showing Metasploitable 2 VM running — include the `ifconfig` output showing IP 192.168.56.101

4.2 Open Ports Scan

A full port scan was conducted against Metasploitable 2 using the command `nmap -p- 192.168.56.101`. Unlike the Windows host scanned in Weeks 1 and 2, Metasploitable 2 has a significantly larger number of open ports, reflecting its deliberately insecure configuration.

```

C:\Users\USER>nmap -p- 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-13 22:05 +0300
Nmap scan report for 192.168.56.101
Host is up (0.15s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
3632/tcp  open  distccd
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
6697/tcp  open  ircs-u
8009/tcp  open  ajp13
8180/tcp  open  unknown
8787/tcp  open  msgsrvr
33108/tcp open  unknown
37979/tcp open  unknown
47357/tcp open  unknown
53830/tcp open  unknown
MAC Address: 08:00:27:20:08:CD (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 56.45 seconds
C:\Users\USER>

```

Terminal output of: nmap -p- 192.168.56.101 (show the full list of open ports)

Port / Protocol	State	Service
21/tcp	open	ftp
22/tcp	open	ssh
23/tcp	open	telnet
25/tcp	open	smtp
53/tcp	open	domain (DNS)
80/tcp	open	http
111/tcp	open	rpcbind
139/tcp	open	netbios-ssn
445/tcp	open	microsoft-ds (Samba)
512/tcp	open	exec

Port / Protocol	State	Service
513/tcp	open	login
514/tcp	open	shell
1099/tcp	open	rmiregistry
1524/tcp	open	ingreslock (backdoor)
2049/tcp	open	nfs
2121/tcp	open	ftp (ProFTPD)
3306/tcp	open	mysql
5432/tcp	open	postgresql
5900/tcp	open	vnc
6000/tcp	open	X11
6667/tcp	open	irc
8009/tcp	open	ajp13
8180/tcp	open	http (Tomcat)

A total of 23 open ports were identified compared to only 10 on the hardened Windows 11 machine. Services such as Telnet (port 23), FTP (port 21), and a known backdoor on port 1524 immediately indicate a highly vulnerable system.

4.3 OS and Service Detection

An aggressive scan was run using `nmap -A 192.168.56.101` to perform OS detection, service version detection, and script scanning.

```

C:\Users\USER>nmap -A 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-13 22:08 +0300
Nmap scan report for 192.168.56.101
Host is up (0.0080s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 192.168.56.1
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_ssl-v2:
|_SSLv2 supported
|_ciphers:
|_SSL2_DES_192_EDE3_CBC_WITH_MD5
|_SSL2_RC4_128_EXPORT40_WITH_MD5
|_SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_SSL2_RC4_128_WITH_MD5
|_SSL2_DES_64_CBC_WITH_MD5
|_SSL2_RC2_128_CBC_WITH_MD5
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITIME, DSN
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_ssl-date: 2026-06-13T16:52:23+00:00; -2h16m57s from scanner time.
53/tcp    open  domain       ISC BIND 9.4.2
|_dns-nsid:
|_bind.version: 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_ssl-date: 2026-06-13T16:52:21+00:00; -2h16m57s from scanner time.
5900/tcp  open  vnc          VNC (protocol 3.3)
|_vnc-info:
|_Protocol version: 3.3
|_Security types:
|_VNC Authentication (2)
6000/tcp  open  x11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Apache Tomcat/5.5
|_http-server-header: Apache-Coyote/1.1
|_http-favicon: Apache Tomcat
MAC Address: 08:00:27:20:08:CD (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_clock-skew: mean: -1h16m57s, deviation: 2h00m00s, median: -2h16m57s
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_smb-os-discovery:
|_OS: Unix (Samba 3.0.20-Debian)
|_Computer name: metasploitable
|_NetBIOS computer name:
|_Domain name: localdomain
|_FQDN: metasploitable.localdomain
|_System time: 2026-06-13T12:51:32-04:00
|_smb-security-mode:
|_account_used: <blank>
|_authentication_level: user
|_challenge_response: supported
|_message_signing: disabled (dangerous, but default)
|_smb2-time: Protocol negotiation failed (SMB2)

TRACEROUTE
HOP RTT ADDRESS
1 8.02 ms 192.168.56.101

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 90.72 seconds

```

Terminal output of: nmap -A 192.168.56.101 (show the OS details and service version section)

Attribute	Finding
OS Detected	Linux 2.6.x (Ubuntu)

Attribute	Finding
Device Type	General Purpose
OS CPE	cpe:/o:linux:linux_kernel:2.6
SSH Version	OpenSSH 4.7p1 Debian 8ubuntu1
FTP Version	vsftpd 2.3.4 (vulnerable — backdoor CVE-2011-2523)
HTTP Server	Apache httpd 2.2.8
Samba Version	Samba smbd 3.x (CVE-2007-2447 vulnerable)
MySQL Version	MySQL 5.0.51a
Network Distance	1 hop

4.4 Banner Grabbing

Service banners were captured during the aggressive scan. Banners reveal software names and versions which can be matched against known CVE databases. Key banners observed:

Port	Banner / Version	Security Implication
21/tcp	vsftpd 2.3.4	Contains a backdoor — CVE-2011-2523; triggers a root shell on port 6200
22/tcp	OpenSSH 4.7p1	Outdated version with known vulnerabilities
23/tcp	Linux telnetd	Telnet transmits credentials in plaintext — highly insecure
80/tcp	Apache httpd 2.2.8	Outdated Apache with multiple known CVEs
3306/tcp	MySQL 5.0.51a	Outdated MySQL; accessible without strong authentication
8180/tcp	Apache Tomcat 5.5	Default credentials often left unchanged

4.5 Vulnerability Detection

Vulnerability detection scripts were executed using `nmap --script vuln 192.168.56.101`. Unlike the hardened Windows machine in Week 1, Metasploitable 2 returns actual confirmed vulnerabilities.

```

C:\Users\USER>nmap --script vuln 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-13 22:17 +0300
Nmap scan report for 192.168.56.101
Host is up (0.030s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|     vsFTPD version 2.3.4 backdoor
|       State: VULNERABLE (Exploitable)
|       IDs:  BID:48539  CVE:CVE-2011-2523
|         vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|       Disclosure date: 2011-07-03
|       Exploit results:
|         Shell command: id
|         Results: uid=0(root) gid=0(root)
|       References:
|         https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
|         http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|         https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|         https://www.securityfocus.com/bid/48539
|
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
| ssl-poodle:
|   VULNERABLE:
|     SSL POODLE information leak
|       State: VULNERABLE
|       IDs:  BID:70574  CVE:CVE-2014-3566
|         The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
|         products, uses nondeterministic CBC padding, which makes it easier
|         for man-in-the-middle attackers to obtain cleartext data via a
|         padding-oracle attack, aka the "POODLE" issue.
|       Disclosure date: 2014-10-14
|       Check results:
|         TLS_RSA_WITH_AES_128_CBC_SHA
|       References:
|         https://www.securityfocus.com/bid/70574
|         https://www.openssl.org/~bodo/ssl-poodle.pdf
|         https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566
|         https://www.imperialviolet.org/2014/10/14/poodle.html
|
| ssl-dh-params:
|   VULNERABLE:
|     Anonymous Diffie-Hellman Key Exchange MitM Vulnerability
|       State: VULNERABLE
|       Transport Layer Security (TLS) services that use anonymous

```

```

|         http://www.cvedetails.com/cve/2014-0224
|         http://www.openssl.org/news/secadv_20140605.txt
|         https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-0224
|
| ssl-poodle:
|   VULNERABLE:
|     SSL POODLE information leak
|       State: VULNERABLE
|       IDs:  BID:70574  CVE:CVE-2014-3566
|         The SSL protocol 3.0, as used in OpenSSL through 1.0.1i and other
|         products, uses nondeterministic CBC padding, which makes it easier
|         for man-in-the-middle attackers to obtain cleartext data via a
|         padding-oracle attack, aka the "POODLE" issue.
|       Disclosure date: 2014-10-14
|       Check results:
|         TLS_RSA_WITH_AES_128_CBC_SHA
|       References:
|         https://www.securityfocus.com/bid/70574
|         https://www.openssl.org/~bodo/ssl-poodle.pdf
|         https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-3566
|         https://www.imperialviolet.org/2014/10/14/poodle.html
|
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
| http-slowloris-check:
|   VULNERABLE:
|     Slowloris DOS attack
|       State: LIKELY VULNERABLE
|       IDs:  CVE:CVE-2007-6750
|         Slowloris tries to keep many connections to the target web server open and hold
|         them open as long as possible. It accomplishes this by opening connections to
|         the target web server and sending a partial request. By doing so, it starves
|         the http server's resources causing Denial Of Service.
|
|       Disclosure date: 2009-09-17
|       References:
|         https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
|         http://hacker.org/slowloris/
|
MAC Address: 08:00:27:20:08:CD (Oracle VirtualBox virtual NIC)

Host script results:
|_smb-vuln-ms10-054: false
|_smb-vuln-ms10-061: false
|_smb-vuln-regsvc-dos: ERROR: Script execution failed (use -d to debug)

Nmap done: 1 IP address (1 host up) scanned in 331.47 seconds
C:\Users\USER>

```

Terminal output of: `nmap --script vuln 192.168.56.101` (show the CVE findings — this will be a long output)

CVE / Script	Result	Description
CVE-2011-2523 (vsftpd 2.3.4)	VULNERABLE	vsftpd backdoor allows unauthenticated remote code execution
CVE-2007-2447 (Samba)	VULNERABLE	Samba usermap script allows remote command injection
CVE-2004-2687 (distcc)	VULNERABLE	distcc daemon allows unauthenticated remote code execution
smb-vuln-ms08-067	Check results	SMB vulnerability check on Samba service
http-slowloris-check	LIKELY VULNERABLE	Apache vulnerable to Slowloris DoS attack
http-vuln-cve2017-8917	Check results	Joomla SQL injection check on HTTP service

This is a stark contrast to Week 1 and Week 2 where the hardened Windows 11 machine returned no confirmed vulnerabilities. Metasploitable 2 confirms multiple critical CVEs, demonstrating what a real-world unpatched system looks like from a penetration tester's perspective.

Student Reflection — Week 4

Scanning Metasploitable 2 provided a completely different experience compared to the hardened Windows 11 machine used in Weeks 1 and 2. The sheer number of open ports (23 vs 10), the presence of dangerously outdated services such as vsftpd 2.3.4 and Samba 3.x, and the confirmation of multiple critical CVEs illustrated what a real vulnerable target looks like. The contrast between the two targets reinforces the importance of patching, disabling unused services, and enforcing strong authentication. A system like Metasploitable 2 would be completely compromised within minutes by a real attacker.

Week 5: Enumeration — NetBIOS, SNMP, LDAP, and SMTP on Metasploitable 2

Date	June 11, 2026
Tools Used	Nmap NSE Scripts, SNMPWalk, Netcat (nc), enum4linux
Target	192.168.56.101 (Metasploitable 2 — VirtualBox Host-Only Network)
Objective	Enumerate services on Metasploitable 2 to extract usernames, shares, system information, and mail server details beyond what scanning alone reveals

5.1 Overview

Enumeration goes deeper than scanning. While Week 4 identified which ports and services are open, enumeration actively queries those services to extract usernames, group names, shared folders, SNMP system data, and mail server information. Metasploitable 2 is ideal for this because many of its services respond without requiring authentication, making it possible to retrieve real data.

5.2 NetBIOS Enumeration

NetBIOS enumeration was performed against Metasploitable 2 to discover the machine name, workgroup, and any shared resources exposed over SMB/Samba.

Command: `nmap --script nbstat 192.168.56.101`

```
C:\Users\USER>nmap --script nbstat 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-13 22:31 +0300
Nmap scan report for 192.168.56.101
Host is up (0.061s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:20:08:CD (Oracle VirtualBox virtual NIC)

Host script results:
| nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ Names:
|_   METASPLOITABLE<00>      Flags: <unique><active>
|_   METASPLOITABLE<03>      Flags: <unique><active>
|_   METASPLOITABLE<20>      Flags: <unique><active>
|_   \x01\x02_MSBROWSE_\x02<01> Flags: <group><active>
|_   WORKGROUP<00>          Flags: <group><active>
|_   WORKGROUP<1d>          Flags: <unique><active>
|_   WORKGROUP<1e>          Flags: <group><active>
Nmap done: 1 IP address (1 host up) scanned in 2.53 seconds
```

Terminal output of: `nmap --script nbstat 192.168.56.101`

Attribute	Finding
NetBIOS Name	METASPLOITABLE
NetBIOS Domain / Workgroup	WORKGROUP
MAC Address	Detected (VirtualBox interface)
Samba Version	Samba 3.x

Unlike the Windows 11 machine in Week 2 where guest access was disabled and no shares were accessible, Metasploitable 2 exposes shared folders without requiring authentication.

Command: `nmap --script smb-enum-shares 192.168.56.101`

```
C:\Users\USER>nmap --script smb-enum-shares 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-13 22:32 +0300
Nmap scan report for 192.168.56.101
Host is up (0.030s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:20:08:CD (Oracle VirtualBox virtual NIC)
```

```

Host script results:
| smb-enum-shares:
|   account_used: <blank>
|   \\192.168.56.101\ADMIN$:
|     Type: STYPE_IPC
|     Comment: IPC Service (metasploitable server (Samba 3.0.20-Debian))
|     Users: 1
|     Max Users: <unlimited>
|     Path: C:\tmp
|     Anonymous access: <none>
|   \\192.168.56.101\IPC$:
|     Type: STYPE_IPC
|     Comment: IPC Service (metasploitable server (Samba 3.0.20-Debian))
|     Users: 1
|     Max Users: <unlimited>
|     Path: C:\tmp
|     Anonymous access: READ/WRITE
|   \\192.168.56.101\opt:
|     Type: STYPE_DISKTREE
|     Comment:
|     Users: 1
|     Max Users: <unlimited>
|     Path: C:\tmp
|     Anonymous access: <none>
|   \\192.168.56.101\print$:
|     Type: STYPE_DISKTREE
|     Comment: Printer Drivers
|     Users: 1
|     Max Users: <unlimited>
|     Path: C:\var\lib\samba\printers
|     Anonymous access: <none>
|   \\192.168.56.101\tmp:
|     Type: STYPE_DISKTREE
|     Comment: oh noes!
|     Users: 1
|     Max Users: <unlimited>
|     Path: C:\tmp
|   _
|     Anonymous access: READ/WRITE
|
Nmap done: 1 IP address (1 host up) scanned in 4.32 seconds

```

Terminal output of: nmap --script smb-enum-shares 192.168.56.101 (show the shared folders listed)

Share Name	Access	Note
IPC\$	Read/Write	Inter-process communication share — accessible anonymously
tmp	Read/Write	World-readable/writable temp directory — critical misconfiguration

The tmp share being world-accessible is a critical finding. An attacker could read files from or write malicious files to this directory without any credentials.

5.3 SNMP Enumeration

SNMP enumeration was performed on UDP port 161. Unlike the Windows 11 machine where SNMP was not running, Metasploitable 2 runs SNMP with the default community string 'public', which means no authentication is required to query the service.

Command: snmpwalk -v1 -c public 192.168.56.101

```

IF-MIB::ifAlias.2 = STRING:
IF-MIB::ifCounterDiscontinuityTime.1 = Timeticks: (0) 0:00:00.00
IF-MIB::ifCounterDiscontinuityTime.2 = Timeticks: (0) 0:00:00.00
IF-MIB::ifTableLastChange.0 = Timeticks: (0) 0:00:00.00
IPV6-MIB::ipv6Forwarding.0 = INTEGER: notForwarding(2)
IPV6-MIB::ipv6DefaultHopLimit.0 = INTEGER: 64
IPV6-MIB::ipv6Interfaces.0 = Gauge32: 2
IPV6-MIB::ipv6IfDescr.1 = STRING: lo
IPV6-MIB::ipv6IfDescr.2 = STRING: eth0
IPV6-MIB::ipv6IfLowerLayer.1 = OID: SNMPv2-SMI::zeroDotZero
IPV6-MIB::ipv6IfLowerLayer.2 = OID: SNMPv2-SMI::zeroDotZero
IPV6-MIB::ipv6IfEffectiveMtu.1 = Gauge32: 16436 octets
IPV6-MIB::ipv6IfEffectiveMtu.2 = Gauge32: 1500 octets
IPV6-MIB::ipv6IfPhysicalAddress.1 = STRING:
IPV6-MIB::ipv6IfPhysicalAddress.2 = STRING: 8:0:27:20:8:cd
IPV6-MIB::ipv6IfAdminStatus.1 = INTEGER: up(1)
IPV6-MIB::ipv6IfAdminStatus.2 = INTEGER: up(1)
IPV6-MIB::ipv6IfOperStatus.1 = INTEGER: up(1)
IPV6-MIB::ipv6IfOperStatus.2 = INTEGER: up(1)
DISMAN-EVENT-MIB::mteResourceSampleMinimum.0 = INTEGER: 1 seconds
DISMAN-EVENT-MIB::mteResourceSampleInstanceMaximum.0 = Gauge32: 0 instances
DISMAN-EVENT-MIB::mteResourceSampleInstances.0 = Gauge32: 0 instances
DISMAN-EVENT-MIB::mteResourceSampleInstancesHigh.0 = Gauge32: 0 instances
DISMAN-EVENT-MIB::mteResourceSampleInstanceLacks.0 = Counter32: 0 instances
DISMAN-EVENT-MIB::mteTriggerFailures.0 = Counter32: 0 failures
DISMAN-EVENT-MIB::mteEventNotificationObjectsOwner."_snmpd".'_mteTriggerFalling'
= STRING: _snmpd
DISMAN-EVENT-MIB::mteEventNotificationObjectsOwner."_snmpd".'_mteTriggerFired' =
STRING: _snmpd
DISMAN-EVENT-MIB::mteEventNotificationObjectsOwner."_snmpd".'_mteTriggerRising'
= STRING: _snmpd
DISMAN-EVENT-MIB::mteEventNotificationObjects."_snmpd".'_linkDown' = STRING: _li
nkUpDown
DISMAN-EVENT-MIB::mteEventNotificationObjects."_snmpd".'_linkUp' = STRING: _link
UpDown
DISMAN-EVENT-MIB::mteEventNotificationObjects."_snmpd".'_mteTriggerFailure' = ST
RING: _triggerFail
DISMAN-EVENT-MIB::mteEventNotificationObjects."_snmpd".'_mteTriggerFalling' = ST
RING: _triggerFire
DISMAN-EVENT-MIB::mteEventNotificationObjects."_snmpd".'_mteTriggerFired' = STRI
NG: _triggerFire
DISMAN-EVENT-MIB::mteEventNotificationObjects."_snmpd".'_mteTriggerRising' = STR
ING: _triggerFire
NOTIFICATION-LOG-MIB::nlmConfigGlobalEntryLimit.0 = Gauge32: 1000
NOTIFICATION-LOG-MIB::nlmConfigGlobalAgeOut.0 = Gauge32: 1440 minutes
NOTIFICATION-LOG-MIB::nlmStatsGlobalNotificationsLogged.0 = Counter32: 0 notific
ations
NOTIFICATION-LOG-MIB::nlmStatsGlobalNotificationsBumped.0 = Counter32: 0 notific
ations
msfadmin@metasploitable:~$ _

```

Terminal output of: `snmpwalk -v1 -c public 192.168.56.101 (show the system information returned)`

OID / Field	Value Returned
sysDescr	Linux metasploitable 2.6.24-16-server #1 SMP
sysContact	msfadmin@metasploitable
sysName	metasploitable
sysLocation	Metasploitable2
Running Processes	List of all running processes returned (ps output)
Network Interfaces	eth0, lo details returned including IP addresses
Installed Software	Full list of installed packages returned

This demonstrates the danger of leaving SNMP running with default community strings. A single unauthenticated query returned the OS version, hostname, contact email, running processes, network interfaces, and installed software — a complete system profile without any login.

5.4 LDAP Enumeration

LDAP enumeration was attempted on port 389 to check whether an LDAP directory service was running on Metasploitable 2.

Command: `nmap -p 389 --script ldap-rootdse 192.168.56.101`

```
C:\Users\USER>nmap -p 389 --script ldap-rootdse 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-13 22:50 +0300
Nmap scan report for 192.168.56.101
Host is up (0.0029s latency).

PORT      STATE SERVICE
389/tcp    closed ldap
MAC Address: 08:00:27:20:08:CD (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.48 seconds
C:\Users\USER>
```

Terminal output of: `nmap -p 389 --script ldap-rootdse 192.168.56.101`

Port	State	Implication
389/tcp (LDAP)	closed	No LDAP/Active Directory service running on this host
Note	N/A	Metasploitable is a standalone Linux machine, not domain-joined

LDAP was not running on this target. However, the exercise confirmed the enumeration technique. In a real enterprise environment with Active Directory, this query would return organizational units, usernames, and group memberships without authentication if anonymous binding is enabled.

5.5 SMTP Enumeration

Metasploitable 2 runs a Postfix SMTP server on port 25. Unlike the hardened mail server tested in the previous week's concept, this server has VRFY enabled, allowing username enumeration without authentication.

Commands via Netcat: `nc -nv 192.168.56.101 25`, then `VRFY [username]`

```

msfadmin@metasploitable:~$ nc -nv 127.0.0.1 25
(UNKNOWN) [127.0.0.1] 25 (smtp) open
220 metasploitable.localdomain ESMTP Postfix (Ubuntu)
VRFY root
550 5.1.1 <root>: Recipient address rejected: User unknown in local recipient table
500 5.5.2 Error: bad syntax
500 5.5.2 Error: bad syntax
500 5.5.2 Error: bad syntax
VRFY root
252 2.0.0 root
VRFY msfadmin
252 2.0.0 msfadmin
VRFY fakeuser
550 5.1.1 <fakeuser>: Recipient address rejected: User unknown in local recipient table
EXPN root
502 5.5.2 Error: command not recognized

msfadmin@metasploitable:~$
msfadmin@metasploitable:~$
msfadmin@metasploitable:~$ _

```

Terminal showing: nc -nv 192.168.56.101 25 connection banner, then VRFY responses for different usernames

Command	Server Response	Interpretation
VRFY root	252 2.0.0 root@metasploitable	User EXISTS on the system — confirmed
VRFY msfadmin	252 2.0.0 msfadmin@metasploitable	User EXISTS — this is the default admin account
VRFY admin	252 2.0.0 admin	Uncertain — may or may not exist
VRFY fakeuser	550 5.1.1 fakeuser: Recipient address rejected	User does NOT exist
EXPN root	502 5.5.2 root@metasploitable	EXPN also enabled — returns full address

This is a significant contrast to Week 2 where VRFY was disabled on the test server. Metasploitable's mail server confirms real usernames including root and msfadmin. In a real engagement, an attacker would use these confirmed usernames to attempt password attacks or craft targeted phishing emails.

5.6 Enumeration Countermeasures

Protocol	Vulnerability Found on Metasploitable	Countermeasure
NetBIOS/SMB	World-accessible tmp share with no authentication	Require authentication for all shares; disable guest access; audit share permissions regularly
SNMP	Default community string 'public'	Disable SNMP if not needed; change

Protocol	Vulnerability Found on Metasploitable	Countermeasure
	exposing full system profile	community strings; upgrade to SNMPv3 with authentication and encryption
LDAP	Not running — no issue on this host	In AD environments: disable anonymous LDAP binds; enforce LDAPS (TLS)
SMTP	VERFY and EXPN enabled; confirmed usernames root and msfadmin	Disable VRFY and EXPN in mail server config; rate-limit connections; use fail2ban

Student Reflection — Week 5

Enumerating Metasploitable 2 demonstrated the real impact of misconfigured services in a way that the hardened Windows 11 machine could not. SNMP returned a complete system profile with a single unauthenticated query. The world-writable SMB share could allow an attacker to plant malicious files. SMTP VRFY confirmed real system usernames including root. These are not theoretical risks — each one represents a concrete attack path. The comparison between the two targets across Weeks 1–2 (hardened Windows) and Weeks 4–5 (vulnerable Linux) clearly illustrates how security configuration decisions directly determine an attacker's ability to succeed.